

기술 요구사항 정의서 (Technical Requirements Document)

연락처 관리 웹 서비스 시스템 설계 및 기술 사양서 [v1.1 수정본]

문서명	연락처 관리 웹 서비스(2차 과제) 기술 요구사항 정의서 (TRD)
버전	v1.1 (정합성 충돌 수정본)
기술 스택	Python 3.12, FastAPI, SQLAlchemy 2.0, PostgreSQL 16, Argon2, HTML/JS SPA
수정 내역	① 미인증 에러 코드 수정 (411 → 401 Unauthorized 반영) ② 데이터 모델 확장 사양 명시 (memo 필드 보완)
작성일	2026-07-06

1. 아키텍처 개요 (Architecture Overview)

본 시스템은 1차 과제의 단일 계층 콘솔 구조에서 벗어나, 현대적 웹 애플리케이션의 구조적 표준인 **다계층 아키텍처(Multi-tier Architecture)**를 채택합니다. 프론트엔드는 단일 페이지 웹 화면(SPA)으로 구성되며, 백엔드는 RESTful API 규격을 따르는 API 서버와 영속성 레이어인 관계형 데이터베이스(RDB)로 분리되어 안전하게 결합됩니다.

💡 설계 핵심 패러다임: 철저한 데이터 격리 및 역할 분담

웹 아키텍처 환경에서는 멀티 유저가 동시에 접속하므로, 로그인 정보에 기반한 세션 검증이 모든 데이터 요청의 관문이 됩니다. 시스템은 **총 4개의 핵심 데이터베이스 테이블** 구조로 완벽한 테넌트 격리를 달성합니다.

1-1. 시스템 물리적/논리적 구조 구성

계층 (Tier)	담당 컴포넌트	구현 기술 / 상세 역할
Presentation Tier	클라이언트 브라우저	HTML5, Vanilla JavaScript Fetch API, UI 레이아웃 제어 및 서버 상태 기반 동적 렌더링
Application Tier	API 백엔드 서버	Python 3.12, FastAPI (Asynchronous Web Framework), Uvicorn ASGI Server
Persistence Tier	관계형 데이터베이스	PostgreSQL 16, SQLAlchemy 2.0 ORM, 물리적 데이터 무결성 제어 및 영속성 보장

2. 데이터베이스 모델 및 스키마 설계

PostgreSQL 16 환경에 대응하는 **4개의 논리/물리 테이블**을 설계합니다. 대리키(Surrogate Key) 전략을 사용하여 모든 주 식별자는 자동 증가 정수형(Serial)인 `id`로 단일화합니다.

2-1. 엔티티 관계도 (ERD) 핵심 데이터 흐름

사용자(users)는 N개의 로그인 세션(sessions)과 N개의 카테고리(categories), N개의 연락처(contacts)를 소유합니다. 연락처 테이블은 사용자와 카테고리를 동시에 참조하는 외래키 복합 구조를 가집니다.

2-2. 테이블 사양서

① 사용자 테이블 (users)

컬럼명	데이터 타입	제약 조건	설명
id	SERIAL	PRIMARY KEY	사용자 고유 대리키
username	VARCHAR(20)	NOT NULL, UNIQUE	로그인 아이디 (영문 소문자/숫자 조합)
hashed_password	VARCHAR(255)	NOT NULL	Argon2id 알고리즘으로 단방향 해시된 비밀번호
created_at	TIMESTAMP	DEFAULT CURRENT_TIMESTAMP	가입 일시

② 로그인 세션 장부 테이블 (sessions)

컬럼명	데이터 타입	제약 조건	설명
session_id	VARCHAR(64)	PRIMARY KEY	비밀 토큰 생성 규칙(hex 32bytes)으로 생성된 세션 키
user_id	INTEGER	FOREIGN KEY (users.id) ON DELETE CASCADE	세션 소유 사용자 ID
expires_at	TIMESTAMP	NOT NULL	만료 시점

③ 연락처 카테고리 테이블 (categories)

컬럼명	데이터 타입	제약 조건	설명
id	SERIAL	PRIMARY KEY	카테고리 고유 식별자
user_id	INTEGER	FOREIGN KEY (users.id) ON DELETE CASCADE	카테고리 소유 사용자 ID
name	VARCHAR(50)	NOT NULL	카테고리 명칭 (예: 가족, 친구, 기타 등)

※ 복합 유니크 제약: UNIQUE (user_id, name) - 동일 사용자가 중복된 이름의 카테고리를 만들 수 없도록 제한하되, 타인 간의 이름 중복은 허용함.

④ 연락처 본체 테이블 (contacts)

컬럼명	데이터 타입	제약 조건	설명
id	SERIAL	PRIMARY KEY	연락처 고유 식별자
user_id	INTEGER	FOREIGN KEY (users.id) ON DELETE CASCADE	연락처 소유 사용자 ID
category_id	INTEGER	FOREIGN KEY (categories.id) ON DELETE RESTRICT	소속 카테고리 ID (참조 연락처 존재 시 삭제 제한)
name	VARCHAR(50)	NOT NULL	이름
phone	VARCHAR(11)	NOT NULL	전화번호 (하이픈 제외 숫자로만 11자리)
memo	TEXT	NULL	[확장 사양] 추가 메모 사항 (PRD 제약 대비 기술적 확장 항목)

※ 복합 유니크 제약: UNIQUE (user_id, phone) - 각 사용자 범위 내에서 전화번호 중복 가입을 철저하게 방지함.

3. 파일 및 프로젝트 디렉터리 아키텍처

단일 파일 구성을 금지하고 계층별로 역할을 명확히 분리하여 설계합니다. 시스템은 contact_app/ 루트 하위에 다음과 같은 구조적 컴포넌트를 이룹니다.

```
contact_app/
|
├─ main.py           # FastAPI 앱 객체 초기화, 미들웨어 및 전역 라우터 통합 총괄
├─ database.py       # SQLAlchemy 엔진 생성, SessionLocal 클래스 선언 및 종속성 주입 함수(get_db) 정의
├─ models.py         # SQLAlchemy ORM 매핑 클래스 선언 (Base 상속 4개 객체)
├─ schemas.py        # Pydantic 기반 입출력 DTO 모델 및 데이터 포맷 유효성 검증 규칙 정의
├─ security.py       # Argon2 비밀번호 암호화 해싱 및 검증 모듈
├─ crud.py           # 데이터베이스에 직접 접근하는 순수 데이터 처리 계층 (Query / Command 분리)
|
├─ routers/          # 엔드포인트 계층 분리 폴더
|   ├─ auth.py       # 회원가입, 로그인, 로그아웃 및 내 정보 관리 API 라우터
|   ├─ contacts.py    # 연락처 조회, 생성, 수정, 삭제 비즈니스 통로 라우터
|   └─ categories.py  # 카테고리 관련 CRUD 비즈니스 통로 라우터
|
└─ static/           # 정적 파일 보관 영역
    ├─ index.html     # 싱글 페이지 애플리케이션(SPA) 구조의 단일 웹 뷰 문서
    └─ app.js         # API 통신 Fetch 연동 및 브라우저 DOM 동적 제어 스크립트
```

4. API 명세 및 세션 제어 표준 (RESTful API Specifications)

4-1. 공통 웹 인증 보안 스키마

본 시스템은 무상태성인 HTTP 프로토콜 위에 안전한 상태 유지를 구현하기 위해 **세션 쿠키(Session Cookie)** 방식을 채택합니다. 백엔드에서 secrets 라이브러리를 통해 암호학적으로 안전한 랜덤 토큰을 발행한 후, 브라우저 응답 헤더의 Set-Cookie 속성을 이용해 영속화합니다.

```
Set-Cookie: session_id=hex_token_string; HttpOnly; Path=/; SameSite=Strict
```

로그인이 필요한 모든 보호 대상 API(FR-05 ~ FR-12)는 라우터 진입 단계에서 세션 검증 프로세스를 거치며, 유효하지 않거나 만료된 세션일 경우 비즈니스 로직에 진입하기 전에 즉시 **401 Unauthorized** 표준 오류 코드로 차단합니다.

4-2. 세부 라우팅 매트릭스 [수정본]

기능 ID	메서드	엔드포인트 URI	성공 코드	예외 처리 및 상태 코드
FR-01	POST	/auth/signup	211 Created	422 (형식 위반), 409 (아이디 중복)
FR-02	POST	/auth/login	200 OK	422 (형식 위반), 400 (비밀번호 불일치)
FR-03	GET	/auth/me	200 OK	401 Unauthorized (세션 누락/만료)
FR-04	POST	/auth/logout	200 OK	401 Unauthorized (미로그인 상태)
FR-05	POST	/contacts	211 Created	401 (미인증) , 422 (규칙 오류), 409 (동일 번호 중복)
FR-06	GET	/contacts	200 OK	401 (미인증) ※ 타인 데이터 원천 격리 검색
FR-07	PATCH	/contacts/{id}	200 OK	401 (미인증) , 404 (내 데이터에 해당 id가 없음)
FR-08	DELETE	/contacts/{id}	200 OK	401 (미인증) , 404 (데이터 부재 또는 권한 외부)
FR-09	POST	/categories	211 Created	401 (미인증) , 409 (동일 카테고리명 중복 존재)
FR-10	GET	/categories	200 OK	401 (미인증)
FR-11	PATCH	/categories/{id}	200 OK	401 (미인증) , 404 (권한 없음), 409 (변경명이 이미 존재)
FR-12	DELETE	/categories/{id}	200 OK	401 (미인증) , 404 (부재), 409 (해당 카테고리를 쓰는 연락처 잔존)

5. 데이터 유효성 검증 및 예외 처리 정책

어떤 악의적이거나 비정상적인 입력에도 백엔드 프로세스가 예기치 않게 종료되거나 500 Internal Server Error를 반환하지 않도록 2중 파이프라인 방어 구조를 설계합니다.

5-1. Pydantic 스키마 계층 유효성 검증 규칙 (1차 방어선)

- **아이디(username):** 정규식 `^[a-z0-9]{4,20}$` 제한 (영문 소문자 및 숫자로만 최소 4자, 최대 20자 제한). 위반 시 FastAPI 기본 422 Unprocessable Entity 처리.
- **비밀번호(password):** 최소 4자 이상, 최대 100자 이하의 문자열 포매팅 검증.
- **전화번호(phone):** 정규식 `^010\d{8}$` 제한 (반드시 010으로 시작하는 하이픈이 완전히 소거된 11자리 연속된 숫자 열).

5-2. 비즈니스 런타임 예외 처리 로직 (2차 방어선 - DB 대조군)

데이터베이스의 실제 레코드 상태를 실시간 검색하여 검증 로직을 구동합니다.

엣지 케이스 규칙 상세: 사용 중인 카테고리 삭제 처리

사용자가 특정 카테고리를 삭제 요청 시, 즉시 삭제 쿼리를 날리지 않고 데이터베이스 레이어에서 `SELECT COUNT(*) FROM contacts WHERE user_id = :user_id AND category_id = :category_id`를 실행합니다. 카운트 결과가 `N > 0` 이면 데이터 무결성 제약 위반을 예방하기 위해 즉시 작업을 취소하고 아래 규격화된 포맷으로 예외를 전달합니다.

```
HTTP/1.1 409 Conflict
Content-Type: application/json; charset=utf-8

{
  "detail": "이 카테고리를 사용하는 연락처가 3건 있어 삭제할 수 없습니다. 연락처를 먼저 정리해주세요."
}
```

6. 프론트엔드 SPA 웹 뷰 연동 방식

브라우저 환경은 싱글 페이지 애플리케이션 구조로 단 한 장의 `index.html` 파일 내부에서 JavaScript 제어부를 기반으로 고속 전환 기법을 수행합니다.

6-1. DOM 섹션 가시성 스위칭 논리 구조

화면 상태 전환은 물리적인 주소 이동이 아닌, DOM 요소의 CSS 속성을 변경하는 방식으로 작동합니다.

```
// 세션 체크 또는 로그인 완료에 따른 화면 상태 전이 알고리즘
function switchView(isLoggedIn) {
  const loginSection = document.getElementById('SCR-001-SECTION');
  const managementSection = document.getElementById('SCR-002-SECTION');
```

```

if (isLoggedIn) {
    loginSection.style.display = 'none';
    managementSection.style.display = 'block';
    loadDashboardData(); // 데이터 순차 의존 로딩 호출
} else {
    loginSection.style.display = 'block';
    managementSection.style.display = 'none';
    clearSensitiveDOM();
}
}

```

6-2. 화면 제어의 단일 출처화 (Single Source of Truth)

프론트엔드 자바스크립트 소스 코드 내부에는 에러 메시지 텍스트를 고정하여 하드코딩하지 않습니다. 모든 API 요청 흐름의 예외 구문은 서버에서 반환받은 `response.json()` 객체의 `detail` 필드 값을 그대로 추출하여 브라우저 내 지정된 메시지 출력 창구 영역(SCR-900)에 바인딩합니다.

7. 인수 테스트 시나리오 및 기능 검증 규칙 [수정본]

개발 완료 후 완벽한 배포를 검증하기 위해 기획된 블랙박스 인수 테스트 시나리오는 다음과 같으며, 단 하나의 케이스라도 실패할 경우 시스템 통과를 거부합니다.

TC ID	대상 기능 레이어	조작 및 입력 시나리오	올바른 시스템의 기대 결과 (인수 기준)
TC-01	초기화 시스템	DB 최초 구동 및 백엔드 실행	오류 없이 서버 작동, 4개 테이블 구조 자동 물리 생성 완료
TC-02	가입 및 초기 데이터 생성	새로운 유저 정보로 회원가입 실행	211 반환과 동시에 DB 카테고리 테이블 내 가족/친구/기타 3개 시드 데이터 자동 할당
TC-03	보안 및 접근 격리	비인증 상태로 GET /contacts 강제 API 호출	비즈니스 데이터 노출 차단, 즉시 401 Unauthorized 상태 반환
TC-04	전화번호 유효성 필터	전화번호 항목에 '010-1234-5678' 입력 시도	Pydantic 정규식 위반 감지, 백엔드 로직 진입 전 422 자동 응답 처리
TC-05	고급 계정 데이터 격리	사용자 B가 알아낸 사용자 A 소유의 연락처 id=15를 수정/삭제 요청	403 금지가 아닌 데이터 미존재 상태인 404 Not Found 응답으로 은닉 격리
TC-06	데이터 연속성 검증	데이터 입력 완료 후 백엔드 웹 서버 데몬 완전 재시작	DB 연속성 계층 격리로 인해 기존 데이터 보존 상태 완벽 확인